

## 01

## Password Reset and Account Lockout

Forgotten passwords, expired credentials, locked accounts, MFA problems

**Default priority:** P3 Medium  
(P2 if a VIP or a  
business-critical role)

**Target response / resolution:** Respond in 15  
min / resolve in 30 min

**Handled by:** Tier 1

### Scope

Use this instruction when a user cannot sign in because of a forgotten or expired password, a locked account, or a failed multi-factor authentication (MFA) prompt.

**Related instructions:** WI-10 Security Incidents, WI-11 Mobile Devices, WI-09 Access Requests

### Common symptoms

- "Incorrect password" or "Account locked" message at sign-in
- Password expired and the change prompt fails
- MFA code not received, or authenticator app lost or replaced
- Repeated prompts to sign in to Microsoft 365 or other apps

### Information to collect

- Full name, username, and employee ID
- Which system or application shows the error, and the exact message
- Device in use and whether it is on the corporate network or remote
- When the problem started, and whether the password was changed recently

### Resolution steps

- 1 Verify identity.** Confirm the caller using at least two items from the approved verification list (employee ID, manager name, date of birth on file, callback to the registered number). Never reset on the strength of an email request alone.
- 2 Check account status.** Open the directory console (Active Directory or Entra ID). Check if the account is locked, disabled, expired, or flagged for risky sign-in.
- 3 Find the lockout source.** If the account is locked, review the lockout source (stale mobile mail profile, mapped drive, saved credential, scheduled task) so it does not lock again.
- 4 Unlock or reset.** Unlock the account, or use the self-service reset portal where possible. If you must reset, set a temporary password and require a change at next sign-in.
- 5 Deliver credentials safely.** Give the temporary password by phone or to the registered mobile number. Never put passwords in the ticket, chat, or email.
- 6 Handle MFA issues.** For a lost or replaced phone, verify identity, remove the old authentication method, and guide the user to re-register. Issue a temporary access pass if policy allows.
- 7 Confirm sign-in works.** Stay with the user until sign-in succeeds on the device and on one cloud application. Ask them to update saved passwords on phones and mapped drives.

#### Escalate when

- Account shows signs of compromise (impossible-travel alerts, unknown devices, forwarding rules): raise a security incident (see WI-10)
- Account is disabled by HR or Security and you did not disable it
- Directory sync errors, or the reset fails with a system error

#### Resolution and closure

- Record how identity was verified and the lockout source if found
- Remind the user of the self-service reset portal and password policy
- Close after the user confirms they are signed in and working

## Quick troubleshooting reference

| Symptom                                             | Likely cause                                                               | What to do                                                                                                               |
|-----------------------------------------------------|----------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------|
| Password rejected, but the user is sure it is right | Caps Lock, wrong keyboard layout, cached old password, or expired password | Check the account status and the password last-set date. Ask the user to type it in a visible text box. Reset if needed. |
| Account locks again within minutes                  | Old password saved on a phone, mapped drive, or scheduled task             | Find the lockout source in the directory logs. Have the user update or remove saved credentials on every device.         |
| MFA prompt never arrives                            | Notifications off, phone offline, or wrong time on the phone               | Offer the verification code option. Check the phone's connectivity and clock. Re-register MFA if needed.                 |
| Password change is refused                          | New password breaks policy or is in the history list                       | Explain the rules (length, complexity, reuse) and retry with a new phrase.                                               |
| User cannot reach the reset portal                  | Not registered for self-service reset, or off the network                  | Verify identity, do an assisted reset, then register the user for self-service.                                          |

## Suggested wording for the user

|        |                                                                                                                                             |
|--------|---------------------------------------------------------------------------------------------------------------------------------------------|
| Open   | <i>"Thanks for calling. I can help you get back into your account. First I need to verify who I am speaking with."</i>                      |
| During | <i>"I can see the account was locked after several failed attempts. I am going to find out what caused it so it does not happen again."</i> |
| Close  | <i>"You are signed in now. Please update the password on your phone and any saved logins. Call us straight away if it locks again."</i>     |

## Good practice

### Do

- Verify identity every time, with no exceptions for people you know
- Point users to self-service reset when they are registered
- Look for the lockout source before you unlock
- Stay with the user until sign-in works

### Do not

- Do not reset on the basis of an email or chat message alone
- Do not write passwords in the ticket, chat, or email
- Do not unlock a disabled account without finding out why it was disabled
- Do not skip checking for sign-in alerts on repeat lockouts

## Worked example

A finance analyst reports being locked out every morning at about 9:15, after resetting the password three days ago.

| Ticket note field | Entry                                                                                  |
|-------------------|----------------------------------------------------------------------------------------|
| Issue reported    | Account locks daily at 9:15. Password was changed 3 days ago.                          |
| Checks performed  | Verified identity. Lockout log shows the source is the user's personal phone mail app. |
| Cause             | Mobile mail app still using the old password.                                          |
| Action taken      | Unlocked the account. Updated the saved password on the phone together with the user.  |
| Result            | No lockout over the next two days. Closed after the user confirmed.                    |

## Frequently asked questions

### Q. Can I reset a password for a manager who is travelling and cannot be reached by phone?

Only after the standard identity checks. If the person cannot be verified, ask them to use self-service reset, or ask their manager or HR to confirm through the portal. Never lower the checks for seniority or urgency.

**Q. The user says MFA codes never arrive. What is the fastest safe fix?**

After verifying identity, offer an alternative method already registered (authenticator code, call). If none exists, remove the old method and issue a temporary access pass, then guide re-registration.

**Q. How often should repeated lockouts be treated as a security issue?**

Treat three lockouts in a day with no clear local cause, or any lockout accompanied by sign-ins from unusual places, as a possible attack. Raise a security incident rather than just unlocking.

**Analyst checklist**

- |                                                     |                                                                            |
|-----------------------------------------------------|----------------------------------------------------------------------------|
| <input type="checkbox"/> Verify identity            | <input type="checkbox"/> Handle MFA issues                                 |
| <input type="checkbox"/> Check account status       | <input type="checkbox"/> Confirm sign-in works                             |
| <input type="checkbox"/> Find the lockout source    | <input type="checkbox"/> Ticket note completed using the standard template |
| <input type="checkbox"/> Unlock or reset            | <input type="checkbox"/> User confirmed the issue is resolved              |
| <input type="checkbox"/> Deliver credentials safely |                                                                            |

**Preventing repeat tickets**

- Encourage all users to register for self-service password reset and MFA
- Remind users to update saved passwords on every device after a change
- Send expiry reminders at 14 and 3 days
- Promote the approved password manager